Universidad de Occidente, sede central

Facultad de Ingeniería



Operación Trazabilidad: informe de auditoría de sistemas

P1 · Anthony Samuel Ordoñez Son · 2401002033

P2 · María José Aldana Culajay · 2301002013

P3 · Luis Antonio Vicente Zapón · 2301002003

Auditoría de Sistemas

Ing. Herman Ávila

[Fecha de entrega pendiente de confirmar]

Plantilla de trabajo del equipo

Se adaptó una copia del documento de referencia aportado por P1. El contenido académico anterior se retiró de esta copia. La fuente recibida se conserva por separado. Esta plantilla no contiene resultados de auditoría ni acredita la revisión humana.

Resumen ejecutivo

Responsable: P3. [Completar: Decisiones, riesgos prioritarios y límites, máximo una página.]

Alcance y metodología

Responsable: P2. [Completar: Encargo, período acordado, exclusiones, criterios e independencia.]

Arquitectura, riesgos y controles

Responsable: P2. [Completar: Diagramas y matrices, con referencias a sus anexos.]

Reconstrucción del incidente

Contenido de P1 recibido localmente e incorporado en el anexo siguiente. Revisión humana pendiente.

Hipótesis y análisis forense

Contenido de P1 recibido localmente e incorporado en el anexo siguiente. Revisión humana pendiente.

Respuesta y continuidad

Evaluación y propuestas de P1 incorporadas; BIA, RTO/RPO y revisión de P3 pendientes.

Terceros, privacidad e inteligencia artificial

Responsable: P3. [Completar: Criterios y fuentes verificados por el responsable.]

Hallazgos y plan de acción

Responsable: P3, con aportes del equipo. [Completar: Hallazgos consolidados, acciones, responsables, plazos y comprobación.]

Referencias y anexos

Responsable: P2 integra. [Completar: Citas y referencias APA 7; evidencias, consultas y registro de IA trazables.]

Tabla N. [Título de la tabla]

[Insertar tabla y su fuente. Los valores pendientes se conservan identificados.]

Aporte propio de P1 · integración parcial

Faltan productos terminados de P2/P3. Este borrador no es Informe_Final ni acredita traspasos, firmas o aprobación académica.

Reconstrucción y evaluación forense del incidente

P1: Anthony Samuel Ordoñez Son, 2401002033. Análisis de I4; edición y exportación técnica de I6, preparada para insertar en Plantilla_UdeO_v2.docx: carta, márgenes de 1 pulgada, Times New Roman 12, justificado, interlineado 1.15 y títulos 13 en negrita. Se conserva el formato de la plantilla v2; paginación efectiva en el PDF adjunto. Corte fijo: **15 de octubre de 2026, 23:59:59, UTC−6**. Redacción asistida por Codex; revisión humana pendiente.

Alcance y calidad de evidencia

El expediente reporta pérdida de acceso al CRM, archivos aparentemente cifrados y una nota de extorsión el 14 de octubre de 2026. La hipótesis de ransomware merece investigación, pero la nota no demuestra exfiltración, autoría o alcance. Las declaraciones de Tecnología, proveedor, Desarrollo, Seguridad y administrador de BD son posiciones por contrastar. No se puede atribuir responsabilidad exclusiva al proveedor ni afirmar que los datos están intactos mientras falta la conciliación. El resumen académico es la única fuente de los sucesos; sus E-01–E-10 no son extracciones autenticadas (Proyecto, pp. 3–5).

I2/I3 ejecutaron Q-01–Q-12 en SQL Server 2022 Developer 16.0.4305.5 como auditor_lectura, sobre datos sintéticos v2. Los registros conservan dos bases propias con 16 tablas, 91,800 filas y 18 claves foráneas, 95 comprobaciones por corrida final y 15 CSV idénticos entre bases. Son pruebas de funcionamiento y reproducibilidad, no corroboración independiente del incidente. I4 verificó los archivos y recalculó conteos, intervalos y modelos de volumen mediante Python estándar, sin conectarse nuevamente a SQL Server. Las fechas reales de ejecución y sus hashes constan en Ejecuciones_v1.csv; la procedencia y los límites por evidencia están en PT-20–PT-25.

Cronología, intervalos y desconocidos

La cronología investigada conserva los 13 eventos y las horas reportadas del proyecto, p. 4. La referencia UTC−6 procede del expediente y S-03; añadir ese huso a la representación no verifica un reloj. Se dejan vacías hora original, zona original, corrección y hora normalizada comprobada. La fiabilidad para corroboración forense se clasifica baja por falta de originales, relojes y fuentes independientes; la fidelidad de transcripción sí se cotejó. Solo el evento remoto identifica una cuenta: ext_ops_04. Las demás identidades permanecen desconocidas.

Entre la solicitud de renovación de API del 12 de octubre a las 16:15 y la sesión del 14 a las 02:17 hay 2,042 min (34 h 02 min), sin decisión de autorización aportada. Siguen elevación a las 02:26, lectura a las 02:31, transferencia a las 02:35, cambios de órdenes a las 02:42 y despliegue a las 03:02. La cercanía exige buscar correlaciones de sesión, transacción o proceso; no demuestra una cadena causal. La solicitud API tampoco prueba que se concediese acceso ni que lo usara la misma persona.

Tabla 1. Intervalos entre horas reportadas, sin corrección de reloj comprobada.

Tramo	Minutos	Interpretación limitada
Sesión remota 02:17 → alerta 03:18	61	Distancia entre marcas; no tiempo probado de detección desde intrusión.
Alerta 03:18 → caída 03:42	24	No acredita falta de atención ni intervalo de logs perdidos.
Caída 03:42 → solicitud DR 04:05	23	Solicitud reportada, no inicio demostrado de restauración.
Caída → solo consulta 08:57	315	5 h 15 min hasta disponibilidad parcial reportada.
Caída → escritura 09:37	355	5 h 55 min; incluye 40 min de solo consulta.
Caída → solicitud de conciliación 11:15	453	7 h 33 min; no es conciliación concluida.

No hay asignación, primera acción o cierre de E-07 para medir atención. Falta cobertura continua entre los hitos, especialmente 03:18–03:42 y durante la recuperación. Son vacíos del expediente: no puede afirmarse borrado de logs sin comparar secuencias, contadores, retención, fallas de recolección y copias independientes. La cronología es una selección de eventos, no un registro exhaustivo. Los intervalos y la lista completa están disponibles para P3, sin traspaso registrado.

Se modeló reportada = real + offset; por tanto, la diferencia real es la reportada menos la diferencia de offsets. No hay eventos compartidos autenticados con los que estimar el desfase real ni una cota defendible. En ejercicios **explícitamente hipotéticos**, offsets independientes de ±5 min dan −6 a 14 min entre lectura y transferencia: su orden podría invertirse. Para órdenes→despliegue, los 20 min pasan a 10–30 con ±5, 0–40 con ±10 y −10–50 con ±15. Un CRM adelantado 15 min y un reloj de despliegue atrasado 15 situarían las marcas reales a 02:27 y 03:17; el caso contrario las situaría a 02:57 y 02:47, invirtiéndolas. Esas horas son ejemplos, no correcciones aplicadas. Para caída→consulta, un offset común constante del mismo reloj cancela la diferencia; si fueran relojes distintos con ±15, el intervalo sería 285–345 min. Compartir etiqueta «CRM» no prueba compartir reloj. No son intervalos de confianza (PT-25; Sensibilidad_relojes_I4_v1.csv).

Hipótesis alternativas y causalidad

Tabla 2. Hipótesis pendientes de prueba, sin probabilidades inventadas.

Hipótesis	A favor	En contra o tensión	Confirmaría / debilitaría o descartaría
H-A: un tercero no autorizado usó una credencial de ext_ops_04 y encadenó lectura, extracción y afectación.	Sesión sin MFA, lectura, tráfico externo, alteraciones y caída reportados son compatibles.	No hay vínculo técnico entre pasos; volumen sin contenido y login SQL desconocido. Ningún hecho disponible la refuta por completo.	Confirmar: token/sesión, host y proceso correlacionados, objetos de salida e indicadores de compromiso. Debilitar: flujo autorizado y sesión sin vínculo con SQL; descartar esta cadena específica: trazas completas que asignen sus pasos a procesos independientes.
H-B: una persona con acceso legítimo a la cuenta la utilizó indebidamente.	Acceso externo reportado y alertas previas de gobierno de cuentas justifican investigar uso interno/proveedor.	No se sabe si ext_ops_04 era compartida ni quién tenía la credencial; las cuentas compartidas del laboratorio son controles. No existe prueba de intención.	Confirmar: asignación histórica, acceso al dispositivo, tokens y acciones concordantes. Debilitar: compromiso documentado ajeno al titular; descartar la atribución a una persona requiere trazabilidad que la excluya.
H-C: lectura/transferencia o despliegue legítimos coincidieron con una afectación iniciada por otra vía.	Destino sin clasificar; Desarrollo alega aprobación verbal; no se demuestra unión de eventos.	Cifrado aparente y extorsión requieren explicación adicional; aprobación verbal no está acreditada.	Confirmar actividad legítima: autorización, job, archivos, destino y patrón coincidentes; identificar además la otra vía. Descartar esa legitimidad: contenido no autorizado y cadena de proceso/sesión que una salida y ataque.

Las tres tienen certeza baja como explicación causal. La falta de una prueba contraria no confirma ninguna. Con las horas reportadas, el despliegue sucede después de los cambios de órdenes: sería insuficiente para explicar por sí solo esos cambios anteriores. La sensibilidad muestra por qué tampoco se debe usar ese orden como refutación definitiva sin verificar relojes. Un registro de la misma transacción, token o proceso en dos sistemas aportaría un enlace investigable; dos eventos cercanos aportan correlación temporal.

El mapa causal editable distingue nodos reportados, hipótesis y desconocidos. Las causas inmediatas propuestas —ejecución maliciosa, abuso de credencial o fallo de integración—

permanecen sin demostrar. Como causas de control se investigan autenticación/excepciones (P2), seguimiento de alertas (B1-1) y protección de registros (B1-2); como causas de gobierno, responsabilidades, supervisión de terceros y continuidad (P2/P3). Ninguna es causa raíz probada del incidente. El mapa marca qué evidencia faltante resolvería cada enlace; el laboratorio de permisos tiene una rama separada sin enlace probatorio hacia RedNova.

Lectura, transferencia y órdenes

Se estimó el orden de magnitud de 31,840 clientes con siete campos comerciales del diccionario v2: ID, nombre, departamento, plan, fecha de alta, estado y clasificación. Se tomaron los primeros 31,840 IDs ficticios, sin asumir que fueran los leídos en producción. CSV UTF-8 sin BOM, coma, encabezado y LF ocupa **2,058,909 bytes** (64.66 bytes/fila, incluyendo cabecera prorrateada); JSON Lines compacto UTF-8, con claves y nulos JSON, **5,115,483 bytes** (160.66 bytes/fila). No se incluyen columnas de procedencia del laboratorio, compresión ni transporte. Se conservan campos, convenciones y hashes de ambas serializaciones en el cálculo reproducible (PT-22).

Tomar ~1.6 GB como 1.6×10^9 bytes da factores de **777.11** y **312.78** respecto de esos modelos y exigiría aproximadamente **50,251 bytes por registro** si todo el flujo contuviera exactamente una copia de 31,840 filas. La alternativa hipotética 1.6 GiB (2^30 bytes/GiB) exige unos **53,957 bytes por fila**; el expediente dice GB y no autoriza sustituir su unidad. Escenarios también hipotéticos de 1,000, 10,000 y 50,000 bytes/fila darían 0.03184, 0.3184 y 1.592 GB decimales. Muestran sensibilidad al ancho de fila, sin describir una exportación real. El tamaño de almacenamiento SQL no equivale a tamaño serializado; faltan esquema de producción, adjuntos, repetición, compresión, cifrado y bytes exactos.

Un envío único de estos campos sintéticos no explica el orden de magnitud, pero la diferencia tampoco descarta salida de clientes junto a otros objetos. Para hablar de exfiltración se necesitan contenido o identificación de archivos, propietario/clasificación del destino, equipo y proceso de origen, autorización, logs de proxy/cloud y comparación con actividad habitual. No se calcula velocidad usando los cuatro minutos entre las marcas: falta inicio/fin del flujo (E-03/E-04, Q-05/Q-06).

El expediente reporta **216 órdenes**, sin campos, montos, vía o responsable. Q-07 reproduce 216 cambios de 216 órdenes distintas; por S-P1-ORD, 144 cambian monto y 72 estado, todos a las 02:42. Python cotejó las 216 filas completas con el historial v2; los 216 UsuarioID, SesionID y Via son desconocidos. Los valores de ejemplo no permiten cuantificar impacto. Q-08 contiene diez pares candidatos, 20 órdenes sin intersección con aquellas 216; faltan request IDs y facturación para probar duplicidad económica. No se sumaron valores ficticios, se inventaron cuentas ni se imputaron pérdidas. Se requiere comparar antes/después con un respaldo limpio, autorizaciones, ERP y facturas, además de vincular persona, sesión y transacción (PT-23).

Evaluación de respuesta y decisiones recomendadas

La alerta crítica y la solicitud DR prueban únicamente lo reportado. ¿Se aislaron activos y se revocaron sesiones/credenciales? No se aportó registro. ¿Se preservaron imágenes, memoria o

instantáneas antes de recuperar? No consta. ¿Qué respaldo se usó, cómo se verificó limpio y quién autorizó volver a escribir? Desconocido. Retorno del servicio no equivale a integridad ni erradicación demostradas. Q-09 modela una reducción de 8.2 a 3.2 GiB (−60.976 %) y una programación sin ejecución, pero ambos son supuestos. Su restauración del 1 de julio es un registro histórico ficticio: no se hizo restore en este trabajo. El expediente solo afirma que la última restauración documentada ocurrió varios meses antes.

Como referencia voluntaria se aplicaron los criterios CR-I4-01/02 y recuperación documentados en Fuentes_P1_v1.md, verificados en los PDFs oficiales de NIST CSF 2.0 y SP 800-61 Rev. 3. Su adopción en RedNova no está acreditada; no se declara incumplimiento normativo. B1-1/B1-2 permanecen no concluyentes, con causas distintas por investigar y sin H definitivo.

Se recomienda que administración designe mando de respuesta, registre decisiones y priorice aislamiento selectivo y revocación de accesos de riesgo, coordinando la captura de datos volátiles y logs antes de cambios cuando sea viable. Ante peligro activo, contener no debe esperar una adquisición perfecta: documentar lo sacrificado, motivo, hora y autorizante, y preservar lo restante. Después, copiar evidencia con hash y acceso restringido, recuperar en infraestructura limpia y mantener el original preservado. Antes de habilitar escritura, verificar respaldo, ausencia de compromiso, integridad y conciliación; acordar criterios de aceptación y seguimiento. Son recomendaciones del auditor, no acciones ejecutadas en la empresa (Acciones_P1_0_72h_v1.csv).

P3 debe aportar BIA, RTO/RPO y criterios de negocio; los 315/355 min no permiten dictaminar su cumplimiento ni un SLA contractual. P2 debe aportar políticas, R/C y borradores para revisión. No se recibieron esos productos ni se realizaron traspasos/revisión cruzada. La revisión humana de P1, captura gráfica SQL, integración del equipo y ensayo físico quedan pendientes. I6 entrega esta sección y sus anexos como paquete propio de P1; no se recibieron aportes terminados de P2/P3. Los cálculos permiten delimitar preguntas y prioridades; una extracción autenticada con sesión, contenido y reloj comprobado podría cambiar estas conclusiones.